

ЗАТВЕРДЖЕНО
Наказом Державна судова адміністрація України
від ____ 2026 р. № ____
(в редакції наказу Державна судова адміністрація України
від ____ 2026 р. № ____)

Єдина судова інформаційно-комунікаційна система (ЄСІКС)
«Верховний Суд»

ЦІЛЬОВИЙ ПРОФІЛЬ БЕЗПЕКИ

UA.46207985.СЗІ.ЦПБ-09

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
1. УПРАВЛІННЯ ДОСТУПОМ (АС) (АС)				
1	ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ ДОСТУПОМ (АС-1)	а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]: 1. 2. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики контролю доступу, яка: (а) містить мету, сферу застосування, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliances); (b) відповідає чинному законодавству, нормативним документам, директивам, нормам, політикам, стандартам і керівним документам. Процедури, що сприяють реалізації політики управління доступом і відповідних заходів управління доступом. б. Призначити на посаду [Призначення: визначену організацією посадову особу] для управління, документування і розповсюдження політики та процедур контролю доступом. с. Переглянути та оновити: 1. поточну політику управління доступом [Призначення: з визначеною організацією частотою] та [Призначення: події, визначені організацією]; 2. поточні процедури управління доступом [Призначення: з визначеною організацією частотою] та [Завдання: події, визначені організацією].	АС-1	Параметр: Визначено персонал або ролі, на які поширюється політика контролю доступу Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури контролю доступу Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами контролю доступу Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою переглядається та оновлюється поточна політика контролю доступу Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено події, які вимагають перегляду та оновлення поточної політики контролю доступу Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури контролю доступу Тип: integer Значення: 30
2	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)	Система забезпечує створення, активацію, зміну та видалення облікових записів відповідно до політик організації. Права доступу жорстко прив'язані до ідентифікатора працівника ('subject_employee') або ролі.	АС-2	Параметр: account_management Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
3	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ (АС-2(3))	Автоматично деактивувати облікові записи коли: а) їх строк дії минув; б) вони більше не пов'язані з користувачем; с) вони порушують організаційну політику; d) вони були неактивними впродовж [Призначення: визначеного організацією періоду часу].	АС-2(3)	Параметр: Облікові записи деактивуються протягом часового періоду, коли облікові записи більше не пов'язані з користувачем або фізичною особою Тип: list Значення: admin, security_officer Параметр: Облікові записи відключено протягом часового періоду, коли облікові записи порушують політику організації; облікові записи деактивуються протягом , якщо вони були неактивними протягом Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Визначено період часу, протягом якого необхідно деактивувати облікові записи Тип: integer Значення: 30 Параметр: Визначено період часу неактивності, після закінчення якого облікові записи будуть деактивовані; АС-02(03)(а) облікові записи деактивуються протягом часового періоду, коли термін дії облікових записів минув Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
4	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ВИХІД ІЗ СИСТЕМИ ЗА ВІДСУТНОСТІ АКТИВНОСТІ (АС-2(5))	Вимагати від користувачів виходити із системи, коли [Призначення: вичерпано визначений організацією період часу очікування або опис того, коли необхідно вийти із системи].	АС-2(5)	Параметр: Користувачі повинні виходити з системи, коли період очікуваної бездіяльності або опис часу, коли потрібно вийти з системи Тип: integer Значення: 30 Параметр: Визначено часовий період очікуваної бездіяльності або опис, коли потрібно вийти з системи Тип: integer Значення: 30
5	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ ОСІБ З ВИСОКИМ РІВНЕМ РИЗИКУ (АС-2(13))	Деактивувати облікові записи користувачів, які становлять значний ризик, у межах [Призначення: визначеного організацією періоду часу] після виявлення ризику.	АС-2(13)	Параметр: Облікові записи користувачів деактивуються протягом періоду часу з моменту виявлення значних ризиків Тип: integer Значення: 30 Параметр: Визначено період часу, протягом якого необхідно деактивувати облікові записи фізичних осіб, які становлять значний ризик Тип: integer Значення: 30
6	ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)	Усі запити до ресурсів системи примусово проходять через Policy Decision Point (PDP) модуля 'abac'. Прямий доступ до даних в обхід механізмів авторизації заборонено архітектурно.	АС-3	Параметр: access_enforcement Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
7	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)	Застосувати затверджені повноваження для управління потоком інформації всередині системи та між пов'язаними системами на основі [Призначення: визначеними організацією політиками управління інформаційним потоком].	АС-4	Параметр: Затверджені повноваження застосовуються для контролю потоку інформації всередині системи та між підключеними системами на основі політики управління інформаційними потоками Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Визначено політики управління інформаційними потоками всередині системи та між підключеними системами Тип: list Значення: default _deny_rule, abac _rule_1
8	РОЗМЕЖУВАННЯ ОBOB'ЯЗКІВ (АС-5)	а. Розмежувати і документувати [Призначення: визначені організацією обов'язки окремих осіб]. б. Установити правила авторизації доступу для підтримки розмежування обов'язків.	АС-5	
9	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (АС-6)	Профілі безпеки і ролі конфігуруються таким чином, що користувачам надаються лише ті привілеї, які необхідні для виконання їхніх посадових обов'язків. Механізм дозволів 'abac' працює за принципом 'Default-Deny'.	АС-6	Параметр: least _privilege Тип: boolean Значення: true
10	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - АВТОРИЗОВАНИЙ ДОСТУП ДО ФУНКЦІЙ БЕЗПЕКИ (АС-6(1))		АС-6(1)	Параметр: Визначені особи або ролі з авторизованим доступом до функцій безпеки та інформації, що має відношення до безпеки Тип: list Значення: admin, security _officer
11	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (АС-6(2))	Вимагати від користувачів облікових записів системи або ролей, які мають доступ до [Призначення: визначених організацією функцій безпеки або інформації, що стосується безпеки], використовувати непривілейовані облікові записи чи ролі під час доступу до незахищених функцій.	АС-6(2)	Параметр: Користувачі облікових записів (або ролей) системи з доступом до функцій безпеки або інформації, що стосується безпеки, повинні використовувати непривілейовані облікові записи або ролі під час доступу до незахищених функцій Тип: list Значення: admin, security _officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
12	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ПРИВІЛЕЙОВАНІ ОБЛІКОВІ ЗАПИСИ (АС-6(5))	Обмежити привілейовані облікові записи в системі згідно з [Призначення: визначеним організацією персоналом або ролями].	АС-6(5)	Параметр: Привілейовані облікові записи в системі обмежено персоналом або ролі Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, яким мають бути обмежені привілейовані облікові записи в системі Тип: list Значення: admin, security_officer
13	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ПЕРЕГЛЯД ПОВНОВАЖЕНЬ КОРИСТУВАЧА (АС-6(7))	а) Переглядати [Призначення: з визначеною організацією частотою] повноваження призначених для [Призначення: визначених організацією посад або класів користувачів] для перевірки необхідності таких повноважень; б) За необхідності перепризначити або зняти повноваження, правильного відображення цілей (місії) організації та потреб організації. для	АС-6(7)	Параметр: Повноваження, призначені ролям і класам, переглядаються з частотою для перевірки необхідності таких повноважень Тип: integer Значення: 30 Параметр: Визначено частоту перегляду повноважень, призначених ролям або класам користувачів Тип: integer Значення: 30 Параметр: Визначено ролі або класи користувачів, яким призначено повноваження Тип: list Значення: admin, security_officer
14	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-6(9))	Реєструвати виконання привілейованих функцій.	АС-6(9)	
15	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (АС-6(10))	Вжити заходи для запобігання можливості виконувати привілейовані функції непривілейованими користувачами.	АС-6(10)	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
16	НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)	а. Встановити обмеження на [Призначення: визначену організацією кількість] послідовних неуспішних спроб входу користувача в систему впродовж [Призначення: визначеного організацією часового періоду]. б. Автоматично виконати [Вибір (один або декілька): блокування облікового запису/вузла на [Призначення: визначений організацією часовий період]; блокування облікового запису/вузла, доки він не буде розблокований адміністратором; затримання наступної команди входу в систему за [Надання: визначеним організацією алгоритмом затримки]; виконати [Призначення: визначені організацією дії]], коли перевищено максимальну кількість невдалих спроб входу в систему.	АС-7	Параметр: Застосовано обмеження на кількість послідовних неуспішних спроб входу користувача протягом періоду часу Тип: integer Значення: 30 Параметр: Визначається кількість послідовних неуспішних спроб входу користувача, дозволених протягом певного періоду часу Тип: integer Значення: 30 Параметр: Визначено період часу, яким обмежується кількість послідовних неуспішних спроб входу користувача Тип: integer Значення: 30 Параметр: Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {заблокувати обліковий запис або вузол на період часу; заблокувати обліковий запис або вузол до зняття адміністратором; затримати наступний запит на вхід за алгоритмом затримки; повідомити системного адміністратора; виконати іншу дію} Тип: string Значення: AES-256-GCM Параметр: Період часу, на який буде заблоковано обліковий запис або вузол (якщо вибрано) Тип: integer Значення: 30 Параметр: Визначено алгоритм затримки наступного запиту на вхід (якщо вибрано) Тип: string Значення: AES-256-GCM Параметр: Інша дія, яка буде виконана після перевищення максимальної кількості невдалих спроб (якщо вибрано) Тип: integer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
17	НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ - ОЧИЩЕННЯ АБО СТИРАННЯ МОБІЛЬНОГО ПРИСТРОЮ (АС-7(2))	Очистити або стерти інформацію з [Призначення: визначених організацією мобільних пристроїв] на основі [Призначення: визначених організацією вимог та методик очищення чи стирання] після [Призначення: визначеної організацією кількості] послідовних невдалих спроб входу в систему з пристрою.	АС-7(2)	Параметр: Інформація очищується або стирається з мобільних пристроїв на основі вимог або методів очищення або стирання після <АС-07(02)_ODP[03 кількість> послідовних, невдалих спроб входу на пристрій Тип: integer Значення: 3 Параметр: Визначається кількість послідовних невдалих спроб входу в систему до того, як інформація буде очищена або стерта з мобільних пристроїв Тип: integer Значення: 3

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
18	ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)	а. б. Демонструвати користувачам [Призначення: визначене організацією сповіщення або банер про використання системи] перед тим, як надавати доступ до системи, що забезпечує безпеку та приватність відповідно до чинних законів, нормативних документів, наказів, директив, політик, правил, стандартів і керівних принципів, які зазначають, що: 1. користувачі здійснюють доступ до урядової системи; 2. використання системи може контролюватися, реєструватися та підлягати аудиту; 3. несанкціоноване використання системи забороняється та приводить до кримінальної та цивільної відповідальності; 4. використання системи означає згоду на моніторинг і запис дій користувача. Зберігати сповіщення або банер на екрані, доки користувачі не визнають умови використання та не приймуть явних дій для входу в систему або подальшого доступу до системи. с. Для загальнодоступних систем: 1. демонструвати інформацію про умови використання системи [Призначення: визначені організацією умови], перш ніж надавати подальший доступ до загальнодоступної системи; 2. демонструвати посилання, якщо такі є, на моніторинг, запис або аудит, які узгоджуються з акомодацією приватності для таких систем, які зазвичай забороняють такі дії; 3. мати опис авторизованого використання системи.	АС-8	Параметр: Визначається сповіщення або банер про використання системи, який система буде показувати користувачам перед наданням доступу до системи; визначено умови використання системи, які система відображатиме перед наданням подальшого доступу; повідомлення про використання системи відображається користувачам перед наданням доступу до системи, яке містить повідомлення про конфіденційність і безпеку, що відповідають чинним законам, нормативним документам, наказам, директивам, політикам, правилам, стандартам і керівним принципам; у повідомленні про використання системи зазначено, що користувачі отримують доступ до урядової системи; у повідомленні про використання системи зазначено, що використання системи може контролюватися, реєструватися та підлягати аудиту; у повідомленні про використання системи зазначено, що несанкціоноване використання системи заборонено і тягне за собою кримінальну та цивільну відповідальність; у повідомленні про використання системи зазначено, що використання системи означає згоду на моніторинг і запис дій; сповіщення або банер залишається на екрані до тих пір, поки користувачі не визнають умови використання та не приймуть явні дії для входу в систему або подальшого доступу до неї; для загальнодоступних систем інформація про використання системи умови відображається перед наданням

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
19	БЛОКУВАННЯ ПРИСТРОЮ (АС-11)	Сеанс користувача автоматично блокується системою ('sync/n2o' session expiry) після визначеного періоду бездіяльності, вимагаючи повторної автентифікації.	АС-11	Параметр: session_lock_timeout Тип: integer Значення: 900
20	БЛОКУВАННЯ ПРИСТРОЮ - ПРИХОВАНІ ДИСПЛЕЇ (АС-11(1))		АС-11(1)	
21	Припинення сеансу (АС-12)	Користувач може ініціювати завершення сеансу (logout). Крім того, система примусово завершує сеанси при досягненні максимального часу життя токена або зміни контексту безпеки.	АС-12	Параметр: session_termination Тип: boolean Значення: true
22	АВТОМАТИЗОВАНЕ МАРКУВАННЯ (АС-15)		АС-15	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
23	АТРИБУТИ БЕЗПЕКИ ТА ПРИВАТНОСТІ (АС-16)	a. Визначити засоби для асоціювання (пов'язання) [Призначення: визначених організацією типів атрибутів безпеки та приватності], що приймають [Призначення: визначені організацією значення атрибутів безпеки та приватності] з інформацією, яка зберігається, обробляється та/або передається. b. Пов'язані атрибути безпеки та приватності мають створюватися і зберігатися разом з інформацією. c. Встановити дозволені [Призначення: визначені організацією атрибути безпеки] для [Призначення: систем, визначених організацією]. d. Визначити дозволені [Призначення: визначені організацією значення або діапазони] для кожного з встановлених атрибутів безпеки та приватності.	АС-16	Параметр: Визначено типи атрибутів безпеки, які мають бути пов'язані зі значеннями атрибутів безпеки для інформації, що зберігається, обробляється та/або передається; визначено значення атрибутів конфіденційності для типів атрибутів конфіденційності; визначено системи, для яких мають бути встановлені дозволені атрибути безпеки; визначено системи, для яких мають бути встановлені дозволені атрибути конфіденційності; визначено атрибути безпеки, визначені як частина АС-16(a), які дозволені для систем; визначено атрибути конфіденційності, визначені як частина АС-16(a), які дозволені для систем; визначено значення атрибутів або діапазони для встановлених атрибутів; визначено частоту, з якою слід переглядати атрибути безпеки на предмет відповідності; визначено частоту, з якою слід переглядати атрибути конфіденційності на предмет відповідності; надано засоби для асоціювання типів атрибутів безпеки зі значеннями атрибутів безпеки для інформації, що зберігається, обробляється та/або передається надано засоби для асоціювання типів атрибутів конфіденційності зі значеннями атрибутів конфіденційності для інформації, що зберігається, обробляється та/або передається виникають зв'язки з атрибутами; зв'язки атрибутів зберігаються разом з інформацією; на основі атрибутів, визначених у АС-16_ODP[01] для систем, встановлюються наступні дозволені

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
24	ВІДДАЛЕНИЙ ДОСТУП (АС-17)	Віддалений доступ до системи керується додатковими політиками (наприклад, перевірка IP-адреси, VPN, mTLS), які інтегруються з 'sync/ca' та 'abac' для забезпечення безпеки доступу за межами захищеного периметра.	АС-17	Параметр: remote_access_control Тип: boolean Значення: true
25	ВІДДАЛЕНИЙ ДОСТУП - КЕРОВАНІ ТОЧКИ КОНТРОЛЮ ДОСТУПУ (АС-17(3))		АС-17(3)	
26	ВІДДАЛЕНИЙ ДОСТУП - ПРИВІЛЕЙОВАНІ КОМАНДИ ТА ДОСТУП (АС-17(4))		АС-17(4)	
27	БЕЗДРОТОВИЙ ДОСТУП (АС-18)	а. Установити обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення бездротового доступу. б. Авторизувати бездротовий доступ до системи, перш ніж будуть дозволені такі підключення.	АС-18	
28	БЕЗДРОТОВИЙ ДОСТУП - АВТЕНТИФІКАЦІЯ ТА ШИФРУВАННЯ (АС-18(1))		АС-18(1)	Параметр: Бездротовий доступ до системи захищений за допомогою шифрування Тип: string Значення: AES-256-GCM
29	БЕЗДРОТОВИЙ ДОСТУП - ВІДКЛЮЧЕННЯ БЕЗДРОТОВОЇ МЕРЕЖІ (АС-18(3))		АС-18(3)	
30	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)	а. Встановити обмеження на використання, вимоги до конфігурації, вимоги до підключення і рекомендації щодо впровадження мобільних пристроїв, контрольованих організацією. б. Авторизувати підключення мобільних пристроїв до систем, які експлуатуються організацією.	АС-19	
31	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИХ ПРИСТРОЇВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ (АС-19(1))		АС-19(1)	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
32	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ (АС-19(2))		АС-19(2)	Параметр: КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]. АС-19(03) КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ З НЕІДЕН- ТИФІКОВАНИМ ВЛАСНИКОМ [Вилучено: Включено в МР-07] Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
33	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ОБМЕЖЕННЯ ДЛЯ ЗАСЕКРЕЧЕНОЇ ІНФОРМАЦІЇ (АС-19(4))		АС-19(4)	Параметр: Використання незахищених мобільних пристроїв на об'єктах, що містять системи, які обробляють, зберігають або передають секретну інформацію, заборонено, за винятком випадків, коли на це є спеціальний дозвіл уповноваженої посадової особи; АС-19(04)(b)(01) заборона підключення незахищених мобільних пристроїв до систем з обмеженим доступом застосовується до осіб, яким уповноважена посадова особа дозволила використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(02) дозвіл уповноваженої посадової особи на підключення незахищених мобільних пристроїв до незахищених систем вимагається від осіб, яким дозволено використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(03) заборона використання внутрішніх або зовнішніх модемів чи бездротових інтерфейсів у складі незахищених мобільних пристроїв поширюється на осіб, яким уповноваженою посадовою особою дозволено використовувати незахищені мобільні пристрої під час виконання службових обов'язків, а також на осіб, які не мають права на використання таких пристроїв АС-19(04)(b)(04)[01] вибірковий огляд та

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
34	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ПОВНЕ ШИФРУВАННЯ ПРИСТРОЇВ ТА СХОВИЩ ІНФОРМАЦІЇ (АС-19(5))		АС-19(5)	
35	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)	а. [Вибір (один або кілька): Встановить [Призначення: умови, визначені організацією]; Визначте [Призначення: визначені організацією засоби контролю, які, як стверджується, будуть реалізовані на зовнішніх системах]], узгоджені з довірчими відносинами, встановленими з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи, дозволяючи уповноваженим особам: 1. доступ до системи із зовнішніх систем; 2. обробляти, зберігати або передавати керовану організацією інформацію за допомогою зовнішніх систем; б. Заборонити використання [Призначення: організаційно-визначені типи зовнішніх систем].	АС-20	Параметр: Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити умови та положення; визначити заходи захисту} Тип: list Значення: Параметр: Визначено умови та положення, що відповідають довірчим відносинам, встановленим з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи (якщо вибрано) Тип: list Значення:

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
36	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ - ОБМЕЖЕННЯ НА АВТОРИЗОВАНЕ ВИКОРИСТАННЯ (АС-20(1))		АС-20(1)	Параметр: Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після перевірки виконання заходів безпеки та конфіденційності, зазначених у політиці безпеки та конфіденційності організації, а також планах безпеки та конфіденційності (якщо такі застосовуються) Тип: list Значення: admin, security_officer Параметр: Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після збереження погоджених угод про підключення або обробку системи з структурою організації, на якій розміщена зовнішня система Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
37	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ - ПЕРЕНОСНІ ПРИСТРОЇ ЗБЕРІГАННЯ ДАНИХ (АС-20(2))		АС-20(2)	Параметр: Використання портативних пристроїв носіїв інформації уповноваженими особами обмежено у зовнішніх системах за допомогою обмеження Тип: list Значення: admin, security_officer Параметр: Визначено обмеження на використання авторизованими особами портативних носіїв інформації у зовнішніх системах Тип: list Значення: admin, security_officer
38	ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)	a. Призначити осіб, що уповноважені на розміщення інформації в загальнодоступній системі. b. Навчати уповноважених осіб тому, щоб загальнодоступна інформація не містила інформацію з обмеженим доступом. c. Переглядати запропонований зміст інформації до публікації в загальнодоступній системі, щоб гарантувати, що там не міститься інформація з обмеженим доступом. d. Переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом з [Призначення: визначеною організацією частотою]; така інформація має бути видалена в разі її виявлення.	АС-22	Параметр: Визначені особи уповноважені на розміщення інформації в загальнодоступній системі Тип: list Значення: admin, security_officer Параметр: Уповноважені особи проходять навчання, щоб гарантувати, що загальнодоступна інформація не містить інформацію з обмеженим доступом Тип: list Значення: admin, security_officer Параметр: Зміст у загальнодоступній системі перевіряється на наявність інформації з обмеженим доступом з частотою Тип: integer Значення: 30 Параметр: Визначено частоту, з якою слід переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом Тип: integer Значення: 30
2. ОБІЗНАНІСТЬ ТА НАВЧАННЯ (АТ) (АТ)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
39	ПОЛІТИКА ТА ПРОЦЕДУРИ ПІДВИЩЕННЯ ОБІЗНАНОСТІ ТА НАВЧАННЯ (AT-1)	а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики обізнаності та навчання у сфері забезпечення безпеки та приватності, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам. 2. Процедури, що сприяють реалізації політики підвищення обізнаності та професійної підготовки в галузі безпеки, приватності, а також пов'язаних з ними заходів захисту інформації та персональних даних. б. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами підвищення обізнаності та навчання у сфері забезпечення безпеки та приватності. с. Переглядати та оновлювати: 1. Поточну політику [Призначення: частота, визначена організацією] і наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].	AT-1	
40	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (AT-2)	Програми навчання та інструктажі (див. розділ AT у digital-profile.pdf).	AT-2	Параметр: security_awareness_training_ref Тип: string Значення: digital-profile.pdf
41	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ	Ввести до програми навчання вправи з розпізнавання та виявлення потенційних індикаторів внутрішніх загроз.	AT-2(2)	
42	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ	Ввести до програми навчання вправи з підвищення обізнаності щодо розпізнавання та повідомлення про потенційні та фактичні атаки, з використанням методів соціальної інженерії та інтелектуального аналізу соціальних даних.	AT-2(3)	
43	РОЛЬОВЕ НАВЧАННЯ (AT-3)	Спеціалізоване навчання для адміністраторів (див. розділ AT у digital-profile.pdf).	AT-3	Параметр: role_based_training_ref Тип: string Значення: digital-profile.pdf
3. АУДИТ ТА ПІДЗВІТНІСТЬ (AU) (AU)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
44	Політика та процедури аудиту та підзвітності (AU-1)	а. Розробити, задокументувати та поширити [Призначення: серед персоналу або ролей, що їх визначила організація]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика аудиту та підзвітності, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам. 2. Процедури, що сприяють здійсненню політики аудиту та підзвітності, а також пов'язані з ними заходи аудиту та підзвітності. б. Призначити [Призначення: визначену організацією старшу посадову особу] для управління політикою та процедурами аудиту та підзвітності. с. Переглядати та оновлювати поточний аудит та підзвітність: 1. політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. процедури аудиту [Призначення: визначеною організацією частотою] та [Завдання: події, визначені організацією].	AU-1	Параметр: Розроблено та задокументовано політику аудиту та підзвітності Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика аудиту та підзвітності доведена до персоналу або ролі Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури аудиту та підзвітності, що сприяють впровадженню політики аудиту та підзвітності, а також відповідні заходи контролю аудиту та підзвітності Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління політикою та процедурами аудиту та підзвітності AU-01(c)[01][01] переглядається та оновлюється поточна політика аудиту та підзвітності з частотою; AU-01(c)[01][02] переглядається та оновлюється поточна політика аудиту та підзвітності після подій; AU-01(c)[02][01] переглядається та оновлюється поточні процедури аудиту та підзвітності з частотою; AU-01(c)[02][02] переглядається та оновлюється поточні процедури аудиту та підзвітності після подій Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, до яких має бути доведена політика аудиту та підзвітності Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
45	ПОДІЇ АУДИТУ (AU-2)	а. Визначити типи подій, які система може реєструвати для підтримки функції аудиту: [Призначення: типи подій, визначені організацією, які система здатна реєструвати]; б. Координувати функції аудиту безпеки з іншими організаційними підрозділами, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються; с. Визначити, які типи подій підлягають аудиту: [Призначення: визначені організацією події, що підлягають аудиту (підмножина подій, що підлягають аудиту, визначених в AU-2 а.), а також частота (або ситуація, що вимагає) проведення аудиту для кожної ідентифікованої події] д. Обґрунтувати, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та приватністю; е. Перегляньте й оновіть типи подій, вибрані для журналювання [Призначення: частота, визначена організацією].	AU-2	Параметр: Зазначені типи подій реєструються 02_ODP[03] частота або ситуація>; <AU- Тип: string Значення: щорічно Параметр: Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота. у системі Тип: string Значення: щорічно Параметр: Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події Тип: list Значення: login, logout, failed_attempt Параметр: Частота перегляду та оновлення типів подій, обраних для журналювання Тип: string Значення: щорічно
46	ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)	Інформація в логах BPMN (особливо при збереженні об'єктів ВРЕ/АВАС) містить вичерпні метадані: тип події, суб'єкт, цільовий об'єкт, результат операції (Permit/Deny) та позначку часу, що повністю закриває вимоги AU-3.	AU-3	Параметр: audit_content_metadata Тип: boolean Значення: true
47	ЗМІСТ ЗАПИСІВ АУДИТУ - ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ (AU-3(1))		AU-3(1)	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
48	РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5)	а. Сповіщати [Призначення: визначені організацією персонал або посади] у разі збою обробки даних аудиту в [Призначення: визначений організацією період часу]. б. Виконати наступні додаткові дії: [Призначення: визначені організацією дії, які необхідно зробити].	AU-5	Параметр: Персонал або ролі отримують сповіщення у разі збою процесу обробки даних аудиту періоду часу Тип: list Значення: admin, security_officer Параметр: Додаткові дії виконуються у разі збою процесу обробки даних аудиту Тип: list Значення: login, logout, failed_attempt Параметр: Визначено персонал або ролі, які отримують сповіщення про збої в процесі обробки даних аудиту Тип: list Значення: admin, security_officer Параметр: Визначено період часу, протягом якого персонал або ролі отримують сповіщення про збої в процесі обробки даних аудиту Тип: list Значення: admin, security_officer Параметр: Визначено додаткові дії, яких слід вжити у випадку збою в процесі обробки даних аудиту Тип: list Значення: login, logout, failed_attempt
49	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)	Аналіз аудиту відбувається за допомогою консольних інструментів платформи (наприклад, 'kvs:hist/1' або інтерфейсів Erlang Shell). Також доступний експорт журналів для SIEM.	AU-6	Параметр: audit_analysis_tools Тип: boolean Значення: true
50	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ - ЗІСТАВЛЯННЯ СХОВИЩ АУДИТУ (AU-6(3))	Аналізувати та зіставляти записи аудиту в різних сховищах задля забезпечення ситуативної обізнаності в масштабах організації.	AU-6(3)	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
51	СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7)	Забезпечити та реалізувати можливості скорочення записів перевірок аудитом і звітів, до рівня, який: а. підтримує перевірку, аналіз і звітність аудиту на вимогу та розслідування (постфактум) інцидентів безпеки; б. не змінює оригінальний вміст або час упорядкування записів аудиту.	AU-7	Параметр: Забезпечено можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту Тип: integer Значення: 30 Параметр: Реалізовано можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту Тип: integer Значення: 30
52	ПОЗНАЧКА ЧАСУ (AU-8)	а. Використовувати внутрішньосистемний годинник для створення позначок часу для записів аудиту. б. Застосовувати позначки часу, які відповідають [Призначення: деталізація вимірювання часу, визначена організацією] і використовують всесвітній координований час, мають фіксоване зміщення місцевого часу відносно всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу.	AU-8	Параметр: Внутрішній системний годинник використовується для створення позначок часу для записів аудиту Тип: integer Значення: 30 Параметр: Позначки часу застосовуються для записів аудиту, які відповідають деталізація вимірювання часу і які використовують всесвітній координований час, мають фіксоване місцеve зміщення місцевого часу від всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу Тип: integer Значення: 30 Параметр: Визначено деталізацію вимірювання часу для часових позначок записів аудиту Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
53	ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)	а. Захист інформації аудиту та інструментів несанкціонованого доступу, зміни та видалення; журналювання аудиту від б. Сповіщення [Призначення: персонал або ролі, визначені організацією] у разі виявлення несанкціонованого доступу, зміни або видалення інформації аудиту.	AU-9	Параметр: Персонал або ролі отримують сповіщення при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, які мають бути сповіщені при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту Тип: list Значення: admin, security_officer
54	ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ - ДОСТУП, ЯКИЙ НАДАЄТЬСЯ ЧЕРЕЗ ЧЛЕНСТВО В ПІДМНОЖИНИ ПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (AU-9(4))	Авторизувати доступ до управління функціональністю аудиту тільки для [Призначення: визначеної організацією підмножини привілейованих користувачів].	AU-9(4)	
55	НЕСПРОСТОВНІСТЬ (AU-10)	Надавайте неспростовні докази того, що особа (або процес, який діє від імені особи) виконала [Призначення: дії, визначені організацією, на які поширюється принцип неспростовності].	AU-10	Параметр: Надаються неспростовні докази того, що особа (або процес, що діє від імені особи) виконала дії Тип: list Значення: admin, security_officer Параметр: Визначено дії, на які поширюється принцип неспростовності Тип: list Значення: login, logout, failed_attempt
56	НЕСПРОСТОВНІСТЬ - ЦИФРОВІ ПІДПИСИ (AU-10(5))		AU-10(5)	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
57	ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11)	Зберігати записи аудиту впродовж [Призначення: визначеного організацією періоду часу, відповідно політиці зберігання записів], щоб забезпечити підтримку розслідувань (постфактум) інцидентів безпеки та приватності, а також для задоволення вимог нормативних і документів організації щодо збереження даних аудиту.	AU-11	Параметр: Записи аудиту зберігаються впродовж період часу, щоб забезпечити підтримку розслідування (постфактум) інцидентів безпеки та конфіденційності, а також відповідати нормативним та вимогам організації щодо збереження даних аудиту Тип: integer Значення: 30 Параметр: Визначено період часу для зберігання записів аудиту, який узгоджується з політикою зберігання записів Тип: list Значення: default _deny_rule, abac_rule_1
58	ГЕНЕРАЦІЯ ДАНИХ АУДИТУ (AU-12)	KVS забезпечує генерацію записів аудиту для всіх операцій створення, оновлення (через створення нової ревізії) та видалення, гарантуючи фіксацію критичних подій безпеки.	AU-12	Параметр: audit_generation Тип: boolean Значення: true
4. ОЦІНЮВАННЯ, АВТОРИЗАЦІЯ ТА МОНІТОРИНГ (CA) (CA)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
59	ПОЛІТИКА І ПРОЦЕДУРИ ОЦІНЮВАННЯ, АКРЕДИТАЦІЯ ТА МОНІТОРИНГ БЕЗПЕКИ (СА-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика оцінювання, авторизації та моніторингу, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, наказам, положенням, політиці, стандартам і керівним принципам. 2. Процедури, що сприяють реалізації політики оцінювання, авторизації та моніторингу безпеки та приватності, а також пов'язаних з ними заходів оцінювання, авторизації та моніторингу безпеки та приватності. б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; с. Переглядати та оновлювати поточне оцінювання, авторизацію та моніторинг: 1. Політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].	СА-1	Параметр: Розроблено та задокументовано політику оцінювання, авторизації та моніторингу Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика оцінювання, авторизації та моніторингу поширюється серед персоналу або ролей Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури оцінювання, авторизації та моніторингу, що сприяють впровадженню політики оцінювання, авторизації та моніторингу, а також пов'язані з ними засоби контролю оцінювання, авторизації та моніторингу Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; СА-01(c)[01][01] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу з частотою; СА-01(c)[01][02] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу після подій; СА-01(c)[02][01] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу з частотою; СА-01(c)[02][02] переглядаються та оновлюються поточні процедури оцінки,

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
60	ОЦІНЮВАННЯ (СА-2)	а. Виберіть відповідного оцінювача або команду з оцінки для типу оцінювання, яке буде проводитися; б. Розробіть план контрольної оцінки, який описує обсяг оцінки, в тому числі: 1. заходи захисту та посилені заходи, що підлягають оцінюванню; 2. процедури оцінювання, ефективності заходів; які використовуватимуться для визначення 3. середовище оцінювання, групу оцінювання, ролі й обов'язки з оцінювання. с. Забезпечити розгляд і затвердження плану оцінювання уповноваженою офіційною особою або призначеним для проведення оцінювання представником; д. Оцінити заходи захисту в системі та в її середовищі функціонування з [Призначення: визначеною організацією частотою] для визначення, наскільки коректно реалізовані заходи безпеки і чи працюють вони за призначенням і дають бажаний результат щодо дотримання встановлених вимог безпеки та приватності; е. Підготувати звіт оцінювання безпеки, який документує результати оцінювання; ф. Надати результати оцінювання з безпеки [Призначення: особам або ролям, визначеним організацією].	СА-2	Параметр: Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи заходи захисту та посилені заходи, що підлягають оцінюванню. СА-02(b)[02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. СА-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. СА-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. СА-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання Тип: list Значення: admin, security_officer Параметр: Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. СА-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. СА-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. СА-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання Тип: list Значення: admin, security_officer Параметр: План оцінки заходів

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
61	ВЗАЄМОДІЯ СИСТЕМ (СА-3)	а. схвалити та керувати обміном інформацією між системою та іншими системами за допомогою [Вибір (один або кілька): угоди безпеки взаємозв'язку; договори безпеки обміну інформацією; меморандуми про взаєморозуміння; угоди про рівень обслуговування; угоди користувача; угоди про нерозголошення; [Доручення: тип договору, визначений організацією]]; б. документувати, як частину угоди про обмін, характеристики інтерфейсу, вимоги до безпеки та приватності, засоби контролю та відповідальність для кожної системи, а також характер переданої інформації; с. здійснювати перегляд та оновлення угод з [Призначення: визначеною організацією частотою].	СА-3	Параметр: Характеристики інтерфейсу задокументовані як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Вимоги до безпеки задокументовані як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Вимоги щодо конфіденційності задокументовані як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Заходи захисту задокументовані як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Відповідальність за кожну систему задокументована як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Характер переданої інформації документується як частина кожної угоди про обмін Тип: integer Значення: 30 Параметр: Угоди переглядаються та оновлюються частота Тип: string Значення: щорічно Параметр: Визначено частоту, з якою необхідно переглядати та оновлювати угоди Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
62	ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (СА-5)	а. Розробити для системи план усунення недоліків та контрольні показники з метою документування запланованих коригувальних дій організації для усунення недоліків і зауважень, які виявлені в ході оцінювання заходів захисту, а також для зменшення або усунення відомих вразливостей у системі. б. Оновлювати чинний план усунення недоліків та контрольні показники з [Призначення: визначеною організацією частотою] на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу.	СА-5	Параметр: Розроблено план усунення недоліків та контрольні показники для системи, та задокументовано заплановані дії організації з коригування, спрямовані на усунення недоліків та зауважень, виявлених під час оцінки заходів захисту, а також на зменшення або усунення відомих вразливостей в системі Тип: list Значення: login, logout, failed_attempt Параметр: Існуючий план оновлюються частота на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу Тип: string Значення: щорічно Параметр: Визначено частоту оновлення чинного плану усунення недоліків та контрольних показників на основі результатів оцінювання заходів захисту, незалежних аудитів та постійного моніторингу Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
63	БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (СА-7)	Розробити стратегію безперервного моніторингу безпеки та приватності й упровадити програму безперервного моніторингу безпеки та приватності, яка охоплює: а. встановлення показників безпеки та приватності, які необхідно відстежувати: [Призначення: визначені організацією метрики]; б. встановлення [Призначення: визначена організацією частота] для моніторингу та [Призначення: визначена організацією частота] для безперервного оцінювання ефективності заходів захисту; с. поточні оцінювання заходів захисту відповідно до стратегії безперервного моніторингу організації; д. постійний моніторинг стану безпеки та приватності відповідно до встановлених організацією метрик і відповідно до стратегії безперервного моніторингу організації; е. зіставлення та аналіз інформації, отриманої в результаті оцінювання та моніторингу безпеки та приватності; ф. дії реагування за результатами аналізу інформації, пов'язаної з безпекою та приватністю; г. повідомлення про статус безпеки та приватності системи [Призначення: визначені організацією персонал або ролі] з [Призначення: визначеною організацією частотою].	СА-7	Параметр: Безперервний моніторинг на рівні системи включає встановлені частоти для моніторингу ефективності заходів захисту Тип: integer Значення: 30 Параметр: Безперервний моніторинг на рівні системи включає встановлені частоти для оцінки ефективності заходів захисту Тип: integer Значення: 30 Параметр: Безперервний моніторинг на рівні системи включає в себе дії з реагування на результати аналізу інформації, пов'язаної з безпекою та приватністю Тип: list Значення: login, logout, failed_attempt Параметр: Безперервний моніторинг на рівні системи включає повідомлення про статус безпеки системи для персоналу або ролей частота Тип: list Значення: admin, security_officer Параметр: Безперервний моніторинг на рівні системи включає повідомлення про стан конфіденційності системи персоналу або ролям частота Тип: list Значення: admin, security_officer Параметр: Визначено частоту, з якою слід моніторити ефективність заходів захисту Тип: integer Значення: 30 Параметр: Визначено частоту, з якою слід оцінювати ефективність заходів захисту Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
5. УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (СМ) (СМ)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
64	Політика та процедури управління конфігурацією (СМ-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначених організацією персоналу або ролей]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики управління конфігурацією, яка: 2. (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, наказам, положенням, політикам, стандартам і керівним принципам; процедури, що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією. b. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією. c. Переглядати та оновлювати поточну політику управління конфігурацією: 1. Політика [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].	СМ-1	Параметр: Розроблено та задокументовано політику управління конфігурацією Тип: list Значення: default _deny_rule, abac _rule _1 Параметр: Політика управління конфігурацією поширюється на персонал або ролі Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури управління , що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією Тип: list Значення: default _deny_rule, abac _rule _1 Параметр: Посадова особа призначається для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією; СМ-01(с)[01][01] переглядається та оновлюється поточна політика управління конфігурацією частота; СМ-01(с)[01][02] переглядається та оновлюється поточна політика управління конфігурацією після події; СМ-01(с)[02][01] переглядаються та оновлюються поточні процедури управління конфігурацією частота; СМ-01(с)[02][02] переглядаються та оновлюються поточні процедури управління конфігурацією після події; ЗНАЧЕННЯ конфігурацією Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на яких поширюється політика управління

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
65	БАЗОВА КОНФІГУРАЦІЯ (СМ-2)	Файл 'grupo.ex' фіксує єдину базову конфігурацію (Baseline) безпеки для всієї системи. Зміни в конфігурації застосовуються виключно через оновлення коду, що забезпечує строгий контроль та аудит змін.	СМ-2	Параметр: baseline_configuration_code Тип: boolean Значення: true
66	БАЗОВА КОНФІГУРАЦІЯ - КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7))	(a) Видавати [Призначення: визначених організацією систем або компонентів систем] з [Призначенням: визначеними організацією конфігураціями] особам, що перебувають у місцях, які організація вважає місцями зі значним ризиком; (b) Застосувати [Призначення: визначені організацією запобіжні заходи безпеки] до компонентів, коли особи повертаються з поїздки.	СМ-2(7)	Параметр: Системи або компоненти системи з конфігураціями видаються особам, що перебувають у місцях, які організація вважає, становлять значний ризик Тип: list Значення: admin, security_officer Параметр: Заходи безпеки застосовуються до систем або компонентів системи, коли особи повертаються з поїздки Тип: list Значення: admin, security_officer Параметр: Визначено системи або компоненти систем, які мають видаватися особам, що перебувають у місцях зі значним ризиком Тип: list Значення: admin, security_officer
67	УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)	Оскільки CMDB є частиною вихідного коду (Elixir модуль), всі зміни проходять через стандартний процес розробки (Code Review, CI/CD, контроль версій Git), унеможливаючи несанкціоноване втручання в налаштування на "живій" системі.	СМ-3	Параметр: configuration_change_control Тип: boolean Значення: true
68	АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (СМ-4)	Аналізувати зміни в системі, щоб визначити потенційну загрозу безпеці та приватності перед реалізацією змін.	СМ-4	
69	АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ - ВЕРИФІКАЦІЯ ФУНКЦІЙ БЕЗПЕКИ ТА ПРИВАТНОСТІ (СМ-4(2))	Після змін у системі переконайтеся, що відповідні заходи захисту реалізовано правильно і вони функціонують належним чином та дають бажаний результат щодо дотримання вимог безпеки та приватності для системи.	СМ-4(2)	
70	ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)	Визначити, задокументувати, затвердити та забезпечити застосування фізичних і логічних обмежень доступу, пов'язаних зі змінами в системі.	СМ-5	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
71	НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6)	Параметри політик безпеки та їхні значення за замовчуванням жорстко зашиті в 'eruno.ex'. Компілятор генерує незмінний об'єктний файл, який гарантує виконання затверджених налаштувань під час роботи.	СМ-6	Параметр: compile_time_config Тип: boolean Значення: true
72	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ (СМ-7)	а. Налаштуйте систему для забезпечення лише [Призначення: основні функції, визначені організацією для місії]; б. Заборонити або обмежити використання таких функцій, портів, протоколів, програмного забезпечення та/або служб: [Призначення: визначені організацією заборонені або обмежені функції, системні порти, протоколи, програмне забезпечення та/або служби].	СМ-7	Параметр: Використання протоколи заборонено або обмежено Тип: string Значення: TLS 1.3 Параметр: Визначено протоколи, які необхідно заборонити або обмежити; СМ-07_ODP[05] визначено програмне забезпечення, яке необхідно заборонити або обмежити Тип: string Значення: TLS 1.3
73	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ - ПЕРІОДИЧНИЙ ПЕРЕГЛЯД (СМ-7(1))		СМ-7(1)	Параметр: Система переглядається частота для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг Тип: string Значення: TLS 1.3 Параметр: Протоколи, які вважаються непотрібними та/або незахищеними, вимкнено Тип: string Значення: TLS 1.3 Параметр: Визначено частоту, з якою слід переглядати систему для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг Тип: string Значення: TLS 1.3 Параметр: Визначено протоколи, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними Тип: string Значення: TLS 1.3

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
74	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ - АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5))	(а) Визначити [Призначення: визначені організацією програмне забезпечення, яке авторизовано виконується в системі] (b) Впровадити політику «заборони всього, за винятком деяких», щоб дозволити виконання авторизованих програм у системі. (с) Переглядати та оновлювати список авторизованих програм [Призначення: з визначеною організацією частотою].	СМ-7(5)	Параметр: Політика "заборонити все, дозволити за винятком" застосовується, щоб дозволити виконання авторизованих програм у системі Тип: list Значення: default _ deny _ rule, abac _ rule _ 1 Параметр: Переглядається та оновлюється список авторизованих програм частота Тип: list Значення: Параметр: Визначено частоту перегляду та оновлення списку авторизованих програм Тип: integer Значення: 30
75	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (СМ-8)	Профіль автоматично фіксує перелік використовуваних компонентів системи (бібліотеки 'sync/kvs', 'sync/ca' тощо) та їхні параметри, забезпечуючи інтегральну інвентаризацію модулів захисту.	СМ-8	Параметр: component _ inventory Тип: boolean Значення: true
76	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ - ОНОВЛЕННЯ ПІД ЧАС ВСТАНОВЛЕННЯ ТА ВИДАЛЕННЯ (СМ-8(1))		СМ-8(1)	
77	РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12)		СМ-12	
6. ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (СР) (СР)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
78	ПЛАН ЗАБЕЗПЕЧЕННЯ БЕЗПЕРЕРВНОЇ РОБОТИ ТА ВІДНОВЛЕННЯ ФУНКЦІОНУВАННЯ (СР-2)		СР-2	Параметр: Розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який визначає основні завдання, функції та пов'язані з ними вимоги щодо безперервної роботи; СР-02(а)[02][01] розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який забезпечує цілі; СР-02(а)[02][02] розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який забезпечує пріоритети; СР-02(а)[02][03] розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який забезпечує відповідні показники; СР-02(а)[03][01] розроблено план забезпечення безперервної роботи на випадок надзвичайних ситуацій для системи, в якому визначено ролі; СР-02(а)[03][02] розроблено план забезпечення безперервної роботи на випадок надзвичайних ситуацій для системи, в якому визначено обов'язки; СР-02(а)[03][03] розроблено план забезпечення безперервної роботи на випадок надзвичайних ситуацій для системи, в якому визначено відповідальних осіб з контактною інформацією Тип: list Значення: admin, security_officer Параметр: Розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який спрямований на повне відновлення

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
79	РЕЗЕРВНЕ КОПЮВАННЯ (CP-9)	Система здійснює автоматичне створення резервних копій бази даних KVS. Бекапи можуть зберігатися локально або відправлятися до хмарних сховищ, гарантуючи відновлення даних відповідно до RTO/RPO.	CP-9	Параметр: system_backup Тип: boolean Значення: true
80	РЕЗЕРВНЕ КОПЮВАННЯ - КРИПТОГРАФІЧНИЙ ЗАХИСТ (CP-9(8))		CP-9(8)	Параметр: Реалізовано криптографічні механізми для запобігання несанкціонованому розкриттю та зміні резервної інформації Тип: string Значення: AES-256-GCM
81	ВІДНОВЛЕННЯ ТА ВІДТВОРЕННЯ СИСТЕМИ (CP-10)	KVS забезпечує механізми швидкого відновлення з резервних копій ('kvs:restore/1'), дозволяючи адміністраторам відновити працездатність вузла з гарантією логічної цілісності журналу транзакцій.	CP-10	Параметр: system_recovery Тип: boolean Значення: true
7. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (IA) (IA)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
82	Політика та процедури ідентифікації та автентифікації (IA-1)		IA-1	Параметр: Розроблено та задокументовано політику ідентифікації та автентифікації Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика ідентифікації та автентифікації поширюється на персонал або ролі Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури ідентифікації та автентифікації, що сприяють впровадженню політики ідентифікації та автентифікації, а також відповідні заходи ідентифікації та перевірки автентичності Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління політикою та процедурами ідентифікації та автентифікації; IA-01(c)[01][01] переглядається та оновлюється поточна політика ідентифікації та автентифікації частота; IA-01(c)[01][02] переглядається та оновлюється поточна політика ідентифікації та автентифікації після подій; IA-01(c)[02][01] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації частота; IA-01(c)[02][02] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації після подій Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
83	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (IA-2)	Система однозначно ідентифікує та автентифікує (перевіряє справжність) організаційних користувачів та процеси, що діють від їх імені, перед тим, як дозволити їм доступ до захищених ресурсів.	IA-2	Параметр: org_user_auth Тип: boolean Значення: true
84	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (IA-2(1))		IA-2(1)	
85	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ НЕПРИВІЛЕЙОВАНИХ (IA-2(2))		IA-2(2)	
86	Ідентифікація та автентифікація (користувачів організації) - Доступ до облікових записів — стійкість до відтворення (IA-2(8))		IA-2(8)	
87	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ПРИЙНЯТТЯ ПОВНОВАЖЕНЬ ДЛЯ ВЕРИФІКАЦІЇ ОСОБИСТОЇ ІНФОРМАЦІЇ (PIV CREDENTIALS) (IA-2(12))		IA-2(12)	Параметр: Приймаються та електронним шляхом підтверджуються повноваження облікових даних особистої ідентифікації Тип: list Значення: admin, security_officer
88	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (IA-3)		IA-3	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
89	УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (IA-4)		IA-4	Параметр: Управління ідентифікаторами здійснюється шляхом отримання дозволу від персоналу або ролей на призначення ідентифікатора особі, групі, ролі або пристрою Тип: list Значення: admin, security_officer Параметр: Управління ідентифікаторами здійснюється шляхом вибору ідентифікатора, який ідентифікує окрему особу, групу, ролі або пристрій Тип: list Значення: admin, security_officer Параметр: Управління ідентифікаторами здійснюється шляхом призначення ідентифікатора особі, групі, ролі або пристрою; IA-04(d) ідентифікатори управляються шляхом запобігання повторному використанню ідентифікаторів впродовж період часу Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, від яких необхідно отримати дозвіл на призначення ідентифікатора Тип: list Значення: admin, security_officer Параметр: Визначено період часу для запобігання повторному використанню ідентифікаторів Тип: integer Значення: 30
90	УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ - ІДЕНТИФІКАЦІЯ СТАТУСУ КОРИСТУВАЧА (IA-4(4))		IA-4(4)	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
91	АВТЕНТИФІКАТОР УПРАВЛІННЯ		ІА-5	Параметр: Управління системними автентифікаторами здійснюється шляхом перевірки, як частини початкового розподілу автентифікатора, особи, групи, ролі або пристрою, який отримує автентифікатор Тип: list Значення: admin, security_officer Параметр: Управління системними автентифікаторами здійснюється шляхом зміни/оновлення автентифікаторів у встановлений період часу або коли відбуваються події Тип: list Значення: login, logout, failed_attempt Параметр: Визначено період часу для зміни або оновлення автентифікаторів за типом автентифікатора Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
92	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (IA-5(1))		IA-5(1)	Параметр: Для автентифікації на основі паролів підтримується та оновлюється список часто використовуваних, очікуваних або скомпрометованих паролів частота, а також коли є підозра, що паролі організації були скомпрометовані прямо чи опосередковано Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі паролів, коли паролі створюються або оновлюються користувачами, паролі перевіряються на відсутність у списку загальновживаних, очікуваних або скомпрометованих паролів в IA-05(01)(a) Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі паролів, паролі передаються лише криптографічно захищеними каналами Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі паролів паролі зберігаються за допомогою затвердженого алгоритму генерування, переважно використовуючи ключову ген-функцію Тип: list Значення: admin, security_officer Параметр: Для автентифікації на основі пароля дозволяється вибір користувачем довгих паролів і фраз, що включають пробіли та всі друковані символи Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
93	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ ВІДКРИТОГО КЛЮЧА (IA-5(2))		IA-5(2)	
94	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ АПАРАТНИХ ТОКЕНІВ (IA-5(11))		IA-5(11)	
95	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - ЕФЕКТИВНІСТЬ БІОМЕТРИЧНОЇ АВТЕНТИФІКАЦІЇ (IA-5(12))		IA-5(12)	Параметр: Визначено вимоги до якості біометрії; для біометричної автентифікації використовувати механізми, які задовольняють вимоги Тип: string Значення: автоматизований засіб моніторингу
96	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - ПРОДУКТИ ТА ПОСЛУГИ, ЗАТВЕРДЖЕНІ УПОВНОВАЖЕНИМ ОРГАНОМ (IA-5(15))		IA-5(15)	
97	УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТОМАТИЗОВАНІ ЗАСОБИ ВИЯВЛЕННЯ АТАК ІЗ ВИКОРИСТАННЯМ БІОМЕТРИЧНИХ АВТЕНТИФІКАТОРІВ (IA-5(17))		IA-5(17)	Параметр: Використовуються механізми виявлення атак із використанням штучно виготовлених артефактів для біометричних автентифікаторів Тип: string Значення: автоматизований засіб моніторингу
98	ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА		IA-6	Параметр: Забезпечено приховану зворотну передачу інформації автентифікації в процесі автентифікації для забезпечення захисту інформації від можливої експлуатації та використання неавторизованими особами Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
99	АВТЕНТИФІКАЦІЯ КРИПТОГРАФІЧНОГО МОДУЛЯ (IA-7)		IA-7	Параметр: Впроваджено механізми автентифікації в криптографічний модуль, який відповідає вимогам чинних законів, виконавчих розпоряджень, директив, політик, правил, стандартів та рекомендацій для такої автентифікації Тип: list Значення: default _ deny _ rule, abac _ rule _ 1
100	ПОВТОРНА АВТЕНТИФІКАЦІЯ (IA-11)		IA-11	
8. РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR) (IR)				
101	Політика та процедури реагування на інциденти (IR-1)	Політика реагування на інциденти задовжена безпосередньо у бізнес-процесах (BPMN) 'erpuno/itsm', забезпечуючи неухильне виконання процедур на кожному кроці життєвого циклу інциденту.	IR-1	Параметр: incident _ policy _ enforcement Тип: boolean Значення: true
102	НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)	Інтерфейс 'erpuno/itsm' надає контекстні підказки та інструкції безпосередньо у формах обробки інцидентів, що виконує функцію інтерактивного навчання та підтримки персоналу в кризових ситуаціях.	IR-2	Параметр: incident _ response _ training Тип: boolean Значення: true
103	ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)	Можливості ВРЕ-движка дозволяють запускати симуляції інцидентів у тестовому середовищі 'itsm' для регулярного тестування планів реагування без впливу на продуктивну систему.	IR-3	Параметр: incident _ testing _ simulation Тип: boolean Значення: true
104	Обробка інциденту (IR-4)	Будь-який інцидент безпеки автоматично реєструється як тикет у модулі 'itsm'. Процес обробки ('incident _ management _ process') гарантує, що інцидент пройде всі необхідні етапи: виявлення, ізоляція, усунення, відновлення.	IR-4	Параметр: incident _ handling Тип: boolean Значення: true
105	Моніторинг інциденту (IR-5)	Статуси інцидентів у реальному часі відображаються на дашбордах 'erpuno/itsm'. ВРЕ-движок дозволяє призначати SLA-таймауту (Boundary Events) для ескалації інцидентів, якщо час реакції перевищено.	IR-5	Параметр: incident _ monitoring Тип: boolean Значення: true
106	ЗВІТНІСТЬ ПРО ІНЦИДЕНТИ (IR-6)	Система 'erpuno/itsm' автоматично формує звіти про інциденти, надаючи вичерпну інформацію про порушені сервіси, час простою (SLA) та дії команди, що закриває вимоги внутрішньої та зовнішньої звітності.	IR-6	Параметр: automated _ incident _ reporting Тип: boolean Значення: true
107	ПІДТРИМКА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-7)	Вбудовані засоби комунікації в рамках тикету (коментарі, призначення експертів, інтеграція з базою знань) забезпечують оперативну допомогу та координацію групи безпеки під час інциденту.	IR-7	Параметр: incident _ assistance Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
108	План реагування на інциденти (IR-8)	Сам конфігураційний код процесів 'eruno/itsm' виступає в ролі актуального та виконуваного плану реагування на інциденти (Executable Incident Response Plan), усуваючи розбіжність між документацією та реальністю.	IR-8	Параметр: executable_ir_plan Тип: boolean Значення: true
9. ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ (МА) (МА)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
109	ПОЛІТИКА ТА ПРОЦЕДУРИ ТЕХНІЧНОГО ОБСЛУГОВУВАННЯ (МА-1)	а. Планувати, документувати та переглядати записи з технічного обслуговування, ремонту або заміни компонентів системи відповідно до вимог виробника та постачальників та/або вимог організації. б. Затвердити та здійснювати моніторинг усіх заходів з технічного обслуговування, незалежно від того, виконуються вони на місці або віддалено, а також чи обслуговуються системи або системні компоненти на місці, чи переміщуються в інше місце. с. Вимагати, щоб [Призначення: визначені організацією персонал чи ролі] явно схвалили видалення системи або компоненту системи з організаційного обладнання для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації. д. Очищати обладнання з погляду видалення всієї інформації з носіїв до вилучення обладнання організації для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації. е. Перевірити всі потенційно порушені заходи захисту, щоб переконатися, що вони, як і раніше, працюють належним чином після дій з обслуговування, ремонту або заміни. ф. Вносити [Призначення: визначену організацією інформацію, пов'язану з технічним обслуговуванням] до записів з технічного обслуговування.	МА-1	Параметр: Розроблено та задокументовано політику технічного обслуговування Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика технічного обслуговування поширюється на персонал або ролі Тип: list Значення: admin, security_officer Параметр: Розроблені та задокументовані процедури технічного обслуговування, що сприяють впровадженню політики технічного обслуговування та пов'язаних з нею заходів технічного обслуговування Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур технічного обслуговування; МА-01(c)[01][01] переглядається та оновлюється поточна політика обслуговування частота; МА-01(c)[01][02] переглядається та оновлюється поточна політика обслуговування після подій; МА-01(c)[02][01] переглядаються та оновлюються поточні процедури технічного обслуговування частота; МА-01(c)[02][02] переглядаються та оновлюються поточні процедури технічного обслуговування після подій Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюється політика технічного обслуговування

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
110	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)	а. Затвердити, контролювати та відстежувати використання засобів технічного обслуговування. б. Переглядати раніше затверджені інструменти технічного [Призначення: з частотою, визначеною організацією]. обслуговування	МА-3	Параметр: Переглядаються раніше затверджені інструменти технічного обслуговування частота Тип: string Значення: щорічно Параметр: Визначено частоту, з якою слід переглядати раніше затверджені інструменти технічного обслуговування Тип: integer Значення: 30
111	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ - ПЕРЕВІРКА ІНСТРУМЕНТІВ (МА-3(1))		МА-3(1)	Параметр: Оглядаються інструменти для технічного обслуговування, які доставлені на об'єкт обслуговуючим персоналом, на предмет неправильних або несанкціонованих модифікацій Тип: list Значення: admin, security_officer
112	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ - ПЕРЕВІРКА НОСІЇВ ІНФОРМАЦІЇ (МА-3(2))	Перед використанням носіїв у системі перевірити носії, що містять діагностичні та тестові програми на наявність шкідливого коду.	МА-3(2)	
113	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ - ЗАПОБІГАННЯ НЕСАНКЦІОНОВАНОМУ ПЕРЕМІЩЕННЮ (МА-3(3))	Запобігти переміщенню обладнання для технічного обслуговування, що містить організаційну інформацію, шляхом: (а) перевірки відсутності організаційної інформації, розміщеної на обладнанні; (б) очищення або знищення обладнання; (с) утримання обладнання на об'єкті; (d) отримання дозволу від [Призначення: визначених організацією персоналу чи ролей], які явно дозволяють переміщення обладнання з об'єкта.	МА-3(3)	Параметр: Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом отримання дозволу від персоналу або ролі Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, які можуть надавати дозвіл на переміщення обладнання з об'єкту Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
114	ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)		МА-4	Параметр: Впроваджено віддалені дії з обслуговування та діагностики Тип: list Значення: login, logout, failed_attempt Параметр: Відстежуються віддалені дії з обслуговування та діагностики Тип: list Значення: login, logout, failed_attempt Параметр: Використання віддалених засобів технічного обслуговування та діагностики дозволено лише відповідно до політики організації Тип: list Значення: default_deny_rule, abac_rule_1

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
115	ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)	а. Встановити процедуру авторизації технічного персоналу та вести перелік авторизованих організацій технічного обслуговування або персоналу. б. Перевіряти, що персонал, який не супроводжується та виконує технічне обслуговування в системі, має необхідні дозволи на доступ. с. Визначити персонал організації з необхідними повноваженнями щодо доступу та технічною компетенцією для нагляду за персоналом з технічного обслуговування, який не має необхідних дозволів на доступ.	МА-5	Параметр: Запроваджено процес авторизації технічного персоналу Тип: list Значення: admin, security_officer Параметр: Ведеться перелік авторизованих організацій або персоналу з технічного обслуговування Тип: list Значення: admin, security_officer Параметр: Персонал без супроводу, який виконує технічне обслуговування системи, має необхідні дозволи на доступ Тип: list Значення: admin, security_officer Параметр: Персонал організації з необхідними повноваженнями доступу та технічною компетентністю призначений/призначені для нагляду за діяльністю з технічного обслуговування персоналу, який не має необхідних дозволів на доступ Тип: list Значення: admin, security_officer
10. ЗАХИСТ НОСІВ ІНФОРМАЦІЇ (МР) (МР)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
116	ПОЛІТИКА ТА ПРОЦЕДУРИ ЩОДО ЗАХИСТУ НОСІЇВ ІНФОРМАЦІЇ (МР-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]: 1. 2. політику захисту носіїв інформації, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (б) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, які сприяють здійсненню політики та заходів захисту носіїв інформації. б. Призначити [Призначення: визначену організацією посадову особу] для управління розробкою, документування, та розповсюдження політики та процедурами захисту носіїв інформації. с. Переглядати та оновлювати чинну систему захисту носіїв інформації: 1. поточну політику захисту носіїв інформації [Призначення: з визначеною організацією частотою]; 2. поточні процедури захисту носіїв інформації [Призначення: з визначеною організацією частотою].	МР-1	Параметр: Розроблено та задокументовано політику захисту носіїв інформації Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Політика захисту носіїв інформації поширюється на персонал або ролі Тип: list Значення: admin, security_officer Параметр: Розроблено та задокументовано процедури захисту носіїв інформації, що сприятимуть реалізації політики захисту носіїв інформації та заходів захисту носіїв інформації Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур захисту носіїв інформації. МР-01(с)[01][01] переглядається та оновлюється поточна політика захисту носіїв інформації частота; МР-01(с)[01][02] переглядається та оновлюється поточна політика захисту носіїв інформації після подій; МР-01(с)[02][01] переглядаються та оновлюються поточні процедури захисту носіїв інформації частота; МР-01(с)[02][02] переглядаються та оновлюються поточні процедури захисту носіїв інформації після подій Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, серед яких має бути поширена політика захисту носіїв інформації

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
117	ДОСТУП ДО НОСІВ ІНФОРМАЦІЇ (МР-2)	Обмежити доступ до [Призначення: визначених організацією типів цифрових та/або нецифрових носіїв інформації] [Призначення: визначеним організацією персоналом або ролями].	МР-2	Параметр: Доступ до типів цифрових носіїв інформації обмежено для персоналу або ролей Тип: list Значення: admin, security_officer Параметр: Доступ до типів нецифрових носіїв інформації обмежено для персоналу або ролей Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, уповноважені на доступ до цифрових носіїв інформації Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, уповноважені на доступ до нецифрових носіїв інформації Тип: list Значення: admin, security_officer
118	МАРКУВАННЯ НОСІВ ІНФОРМАЦІЇ (МР-3)	а. Наносити на носії інформації маркування, що вказують на обмеження поширення, обробки, а також застереження та відповідні мітки безпеки (якщо такі є) інформації. б. Звільнити [Призначення: визначені організацією типи носіїв системи] від маркування, якщо носії залишаються в межах [Призначення: визначених організацією контрольованих зон].	МР-3	Параметр: Визначено типи носіїв інформації, які звільняються від маркування під час перебування на контрольованих зонах Тип: integer Значення: 30
119	ЗБЕРІГАННЯ НОСІВ ІНФОРМАЦІЇ (МР-4)	а. Фізично контролювати та безпечно зберігати [Призначення: визначені організацією типи цифрових та/або нецифрових носіїв інформації] в межах [Призначення: визначених організацією контрольованих зон]. б. Захищати системні носії, які визначені в МР-4 до того часу, як носії знищуються або очищаються, з використанням затвердженого обладнання, методів та процедур.	МР-4	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
120	Транспортування носіїв інформації (MP-5)	a. Захищати та контролювати [Призначення: визначені організацією типи носіїв системи] під час транспортування за межами контрольованих зон, використовуючи [Призначення: визначені організацією заходи безпеки]. b. Вести облік носіїв системи інформації під час транспортування за межами контрольованих зон. c. Документувати дії, пов'язані з транспортуванням носіїв системи. d. Обмежити діяльність уповноваженого персоналу, пов'язану з транспортуванням носіїв системи.	MP-5	Параметр: Типи носіїв інформації системи захищаються під час транспортування за межі контрольованих зон за допомогою заходів безпеки Тип: integer Значення: 30 Параметр: Типи носіїв інформації системи контролюються під час транспортування за межі контрольованих зон за допомогою заходів безпеки Тип: integer Значення: 30 Параметр: Під час транспортування за межі контрольованих зон ведеться облік носіїв інформації системи Тип: integer Значення: 30 Параметр: Визначено персонал, уповноважений здійснювати діяльність з транспортування носіїв інформації Тип: list Значення: admin, security_officer Параметр: Діяльність, пов'язана з транспортуванням носіїв інформації системи, обмежується визначеним уповноваженим персоналом Тип: list Значення: admin, security_officer Параметр: Визначено типи носіїв інформації системи для захисту та контролю під час транспортування за межі контрольованих зон Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
121	ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (MP-6)	а. Очищувати [Призначення: визначені організацією системні носії] перед утилізацією, випуском за межі організаційного контролю, або перед повторним використанням [Призначення: методами та процедурами очищення, визначеними організацією]. б. Використовувати механізми очищення зі стійкістю та цілісністю, що відповідає категорії безпеки або рівню секретності інформації.	MP-6	Параметр: Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації Тип: string Значення: автоматизований засіб моніторингу
122	ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ (MP-7)	а. [Вибір: обмежити; заборонити] використання [Призначення: визначених організацією типів носіїв системи] на [Призначення: визначені організацією системи або компоненти системи], використовуючи [Призначення: визначені організацією заходи безпеки]. б. Заборонити використання портативних пристроїв зберігання даних в системах організації, якщо такі пристрої не мають визначеного власника.	MP-7	
123	ЗНИЖЕННЯ КАТЕГОРІЇ БЕЗПЕКИ НОСІЇВ ІНФОРМАЦІЇ - ТАЄМНА ІНФОРМАЦІЯ (MP-8(4))		MP-8(4)	Параметр: Носії інформації, що містять інформацію з обмеженим доступом, знижуються в класі перед передачею особам, які не мають необхідних дозволів на доступ Тип: list Значення: admin, security_officer
11. ФІЗИЧНИЙ ЗАХИСТ ТА ЗАХИСТ НАВКОЛИШНЬОГО СЕРЕДОВИЩА (PE) (PE)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
124	РЕ-1 фізичного захисту та захисту робочого середовища Авторизація фізичного (РЕ-1)		РЕ-1	Параметр: Розроблено та задокументовано політику фізичного захисту та захисту робочого середовища Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Політика фізичного захисту та захисту робочого середовища розповсюджується серед персоналу або ролей Тип: list Значення: admin, security_officer Параметр: Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур фізичного захисту та захисту робочого середовища; РЕ-01(c)[01][01] переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища частота; РЕ-01(c)[01][02] поточна політика фізичного захисту та захисту робочого середовища переглядається та оновлюється після подій; РЕ-01(c)[02][01] переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища частота; поточні процедури фізичного та екологічного захисту переглядаються та оновлюються після подій. РЕ-01(c)[02][02] Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, до яких має бути доведена політика фізичного захисту та захисту робочого середовища Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури фізичного

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
125	РЕ-2 доступу (РЕ-2)	Регламентується інструкціями з режиму ЦОД (див. розділ РЕ у digital-profile.pdf).	РЕ-2	Параметр: physical_access_doc_ref Тип: string Значення: digital-profile.pdf
126	ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ	Регламентується системами СКУД будівлі (див. розділ РЕ у digital-profile.pdf).	РЕ-3	Параметр: physical_access_control_ref Тип: string Значення: digital-profile.pdf
127	РЕ-4 ліній електроживлення (РЕ-4)		РЕ-4	
128	КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОБРАЖЕННЯ ІНФОРМАЦІЇ		РЕ-5	
129	МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ		РЕ-6	Параметр: Переглядаються журнали фізичного доступу частота Тип: string Значення: щорічно Параметр: Визначено частоту перегляду журналів фізичного доступу Тип: integer Значення: 30 Параметр: Визначено події або потенційні ознаки подій, що вимагають перегляду журналів фізичного доступу Тип: list Значення: login, logout, failed_attempt
130	АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (РЕ-17)		РЕ-17	Параметр: Визначаються заходи захисту, які будуть застосовуватися на альтернативних робочих місцях; РЕ-17(a) альтернативні робочі місця визначені та задокументовані; РЕ-17(b) заходи захисту впроваджені на альтернативних робочих місцях; РЕ-17(c) оцінюється ефективність заходів захисту на альтернативних робочих місцях; РЕ-17(d) працівникам надаються засоби комунікації з персоналом служби інформаційної безпеки на випадок інцидентів Тип: list Значення: admin, security_officer
131	МАРКУВАННЯ КОМПОНЕНТІВ (РЕ-22)		РЕ-22	
12. ПЛАНУВАННЯ (PL) (PL)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
132	ПОЛІТИКИ ТА ПРОЦЕДУРИ ПЛАНУВАННЯ БЕЗПЕКИ (PL-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]: 1. 2. [вибір (один або декілька): рівень організації; рівень місії/бізнес процесу; рівень системи] політику планування, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та системою контролю (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, що полегшують здійснення планування політики безпеки та приватності й пов'язані з ними заходи. б. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами планування політики безпеки та приватності. с. Переглядати та оновлювати поточне планування: 1. політики планування безпеки та приватності [Призначення: з визначеною організацією частотою] та наступні [Призначення: визначені організацією події]; 2. поточні процедури планування політики [Призначення: з визначеною організацією [Призначення: визначені організацією події]. безпеки та приватності частотою] та наступні	PL-1	Параметр: Визначено персонал або ролі, до яких має бути доведена політика планування безпеки Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюватимуться процедури планування безпеки Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами планування безпеки Тип: list Значення: admin, security_officer Параметр: Визначено періодичність перегляду та оновлення поточної політики планування безпеки Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які потребують перегляду та оновлення поточної політики планування безпеки Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначена частота, з якою переглядаються та оновлюються поточні процедури планування безпеки Тип: string Значення: щорічно
133	ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2)	Система підтримує автоматичну генерацію актуального Плану безпеки системи на основі цього профілю (СМ). План чітко визначає всі технічні та організаційні контролю (AC, AU, SC, CM тощо), середовище функціонування та архітектуру.	PL-2	Параметр: system_security_plan Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
134	ПРАВИЛА ПОВЕДІНКИ (PL-4)	Для всіх користувачів платформи (організаційних та зовнішніх) визначаються правила поведінки. Згода з правилами (наприклад, Terms of Service, NDA) фіксується в базі даних KVS під час онбордингу, перед наданням доступу до ERP/1.	PL-4	Параметр: rules_of_behavior Тип: boolean Значення: true
13. БЕЗПЕКА ПЕРСОНАЛУ (PS) (PS)				
135	Політика та процедури кадрової безпеки (PS-1)		PS-1	Параметр: Визначено персонал або ролі, на які поширюється політика кадрової безпеки Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури кадрової безпеки Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами кадрової безпеки Тип: list Значення: admin, security_officer Параметр: Визначена періодичність перегляду та оновлення поточної політики кадрової безпеки Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які вимагають перегляду та оновлення поточної політики кадрової безпеки Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено періодичність перегляду та оновлення поточних процедур кадрової безпеки Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
136	Перевірка персоналу (PS-3)		PS-3	Параметр: Визначені умови, що вимагають повторної перевірки осіб Тип: list Значення: Параметр: Визначена частота повторної перевірки осіб, для яких це показано; PS-03a. проходять особи перевірку перед тим, як надати їм доступ до системи; PS-03b.[01] проходять особи повторну перевірку відповідно до умови, що вимагають повторної перевірки; PS-03b.[02] проводиться повторна перевірка у випадках, коли це зазначено, частота Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
137	Звільнення персоналу (PS-4)		PS-4	Параметр: Визначено період часу, протягом якого забороняється доступ до системи Тип: integer Значення: 30 Параметр: Визначені теми інформаційної безпеки для обговорення під час проведення співбесід; PS-04a. при звільненні працівника доступ до системи вимикається протягом часового періоду; PS-04b. припиняють дію або анулюють будь-які автентифікатори та облікові дані після припинення трудових відносин з окремими особами; PS-04c. проводяться при звільненні окремих працівників співбесіди, які включають обговорення питань інформаційної безпеки; PS-04d. отримується після звільнення особи все майно, пов'язане з безпекою організаційної системи; PS-04e. зберігається доступ до організаційної інформації та систем, які раніше перебували під контролем особи, що звільняється, після припинення нею трудових відносин Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
138	Переведення персоналу (PS-5)		PS-5	Параметр: Визначені дії, які мають бути ініційовані після переведення або перепризначення Тип: list Значення: login, logout, failed_attempt Параметр: Визначено період часу, протягом якого мають бути здійснені дії з переведення або перепризначення після переведення або перепризначення Тип: list Значення: login, logout, failed_attempt Параметр: Визначено персонал або ролі, про які необхідно повідомляти, коли осіб призначають на інші посади або переводять на інші посади в організації Тип: list Значення: admin, security_officer Параметр: Визначено період часу, протягом якого необхідно повідомляти визначений організацією персонал або ролі, коли осіб перепризначають або переводять на інші посади в межах організації; PS-05a. переглядаються та підтверджуються поточні потреби в логічних та фізичних дозволах на доступ до систем та об'єктів при перепризначенні або переведенні осіб на інші посади в організації; PS-05b. були ініційовані дії з переведення або перепризначення протягом періоду часу після формальної дії з переведення; PS-05c. змінюється авторизація доступу за необхідності, щоб відповідати будь-яким змінам в оперативних потребах у зв'язку з перепризначенням або переведенням; PS-05d. було повідомлено персонал або ролі протягом часового періоду Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
14. ОЦІНКА РИЗИКІВ (RA) (RA)				
139	ПОЛІТИКА ТА ПРОЦЕДУРИ ОЦІНЮВАННЯ РИЗИКУ (RA-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]: 1. 2. Політику оцінювання ризику, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і керівним принципам. Процедури, що сприяють здійсненню політики оцінювання ризику та пов'язаних з ними заходів оцінювання ризику. б. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами оцінювання ризику. с. Переглядати й оновлювати: 1. Поточну політику оцінювання організацією частотою]. ризику [Призначення: з визначеною 2. Поточні процедури оцінювання ризику [Призначення: з визначеною організацією частотою].	RA-1	Параметр: Визначено персонал або ролі, на які поширюється політика оцінювання ризику Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури, що сприяють здійсненню політики оцінювання ризику Тип: list Значення: admin, security_officer Параметр: Визначена посадова особа, відповідальна за управління політикою та процедурами оцінювання ризику Тип: list Значення: admin, security_officer Параметр: Визначена періодичність перегляду та оновлення поточної політики оцінювання ризику Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які вимагають перегляду та оновлення поточної політики оцінювання ризику Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено періодичність перегляду поточних процедур оцінювання ризику Тип: string Значення: щорічно
140	ОЦІНЮВАННЯ РИЗИКУ (RA-3)	Всі ідентифіковані вразливості або загрози фіксуються в реєстрі 'itsm', де їм присвоюється рівень критичності. На базі цього рівня розраховується пріоритет та призначаються відповідальні особи.	RA-3	Параметр: risk_assessment Тип: boolean Значення: true
141	ОЦІНЮВАННЯ ПОСТАЧАВАННЯ (RA-3(1))		RA-3(1)	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
142	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5)	Система передбачає можливість інтеграції зовнішніх сканерів вразливостей, звіти яких автоматично перетворюються на тикети усунення ризиків в системі 'itsm'.	RA-5	Параметр: vulnerability_scanning Тип: boolean Значення: true
143	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ - ОНОВЛЕННЯ ЗА ЧАСТОТОЮ, ПЕРЕД НОВИМ СКАНУВАННЯМ АБО ПРИ ІДЕНТИФІКАЦІЇ (RA-5(2))		RA-5(2)	Параметр: Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику Тип: integer Значення: 30
144	РЕАГУВАННЯ НА РИЗИК (RA-7)	Реагувати на результати оцінювання, моніторингу й аудиту безпеки та приватності.	RA-7	
15. ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA) (SA)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
145	ПОЛІТИКИ ТА ПРОЦЕДУРИ ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]: 1. 2. б. [Вибір (один або декілька): рівень організації; рівень місії/бізнес-процесу; рівень системи] політики придбання систем і послуг, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю (compliance); (б) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і рекомендаціям. Процедури, що полегшують впровадження політики та заходів придбання систем і послуг. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами придбання системи та послуг. с. Переглядати й оновлювати поточні політику та процедури придбання систем та послуг: 1. Поточну політику придбання системи та послуг [Призначення: з визначеною організацією частотою]. 2. Поточні процедури придбання системи та послуг [Призначення: з визначеною організацією частотою] та наступні [Призначення: події, визначені організацією].	SA-1	Параметр: Визначено персонал або ролі, на які поширюватиметься політика придбання систем і послуг Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури придбання систем і послуг Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами придбання систем і послуг Тип: list Значення: admin, security_officer Параметр: Визначено періодичність перегляду та оновлення поточної політики придбання систем і послуг Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які вимагають перегляду та оновлення поточної політики придбання систем і послуг Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні процедури придбання систем і послуг Тип: integer Значення: 30
146	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПВ ІНЖИНІРИНГУ (SA-8)	Застосовувати [Призначення: визначені організацією принципи інжинірингу безпеки та конфіденційності системи] в специфікації, проектуванні, розробці, впровадженні та зміні системи й компонентів системи.	SA-8	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
147	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)	а. Вимагати, щоб постачальники зовнішніх послуг для системи відповідали вимогам безпеки та приватності в організації та застосовували такі заходи захисту [Призначення: встановлені організацією заходи безпеки та приватності]. б. Визначити та задокументувати нагляд організаціїповноваження та обов'язки користувачів щодо зовнішніх послуг для системи. с. Використовувати наступні процеси, методи та техніки для постійного моніторингу дотримання контролю зовнішніми постачальниками послуг: [Призначення: визначені організацією процеси, методи та техніки].	SA-9	Параметр: Визначені засоби контролю, які будуть застосовуватися зовнішніми постачальниками системних послуг Тип: string Значення: автоматизований засіб моніторингу Параметр: Визначені процеси, методи та техніки, що застосовуються для моніторингу дотримання вимог контролю зовнішніми постачальниками послуг; SA-09a.[01] дотримуються постачальники зовнішніх системних послуг вимог організаційної безпеки; SA-09a.[02] дотримуються постачальники зовнішніх системних послуг вимог приватності організації; SA-09a.[03] використовують постачальники зовнішніх системних послуг елементи керування; SA-09b.[01] визначено та задокументовано організаційний нагляд за зовнішніми системними послугами; SA-09b.[02] визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних сервісів; SA-09c. визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних послуг Тип: list Значення: admin, security_officer
148	КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)	а. Замінювати компоненти системи, якщо підтримка компонентів більше не доступна розробнику, постачальнику або виробнику. б. Надавати такі варіанти альтернативних джерел для подальшої підтримки непідтримуваних компонентів [Вибір (один або більше): внутрішня підтримка; [Призначення: підтримка, визначена організацією від зовнішніх постачальників]].	SA-22	
16. ЗАХИСТ СИСТЕМ ТА КОМУНІКАЦІЙ (SC) (SC)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
149	ПОЛІТИКА ТА ПРОЦЕДУРИ ЗАХИСТУ СИСТЕМИ ТА КОМУНІКАЦІЙ (SC-1)	а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]: 1. 2. Політику захисту системи та комунікацій, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (б) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам. Процедури для сприяння впровадженню політики в області захисту систем і комунікацій, а також пов'язаних з ними систем і засобів захисту зв'язку. б. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами захисту системи та комунікацій. с. Переглядати та оновлювати: 1. поточну політику захисту системи та комунікацій [Призначення: визначена організацією частота]; 2. поточні процедури захисту системи та комунікацій [Призначення: визначена організацією частота].	SC-1	Параметр: Визначено персонал або ролі, до яких має бути доведена політика захисту системи та комунікацій Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури захисту системи та комунікацій Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, яка керуватиме політикою та процедурами захисту системи та комунікацій Тип: list Значення: admin, security_officer Параметр: Визначена періодичність перегляду та оновлення поточної політики захисту системи та комунікацій Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які вимагають перегляду та оновлення поточної політики захисту системи та комунікацій Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначена періодичність перегляду та оновлення поточних процедур захисту системи та засобів зв'язку Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
150	ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)	Erlang VM не використовує спільну пам'ять (shared memory) між процесами сесій N2O. Пам'ять звільняється автоматично (Garbage Collection) після обробки запиту, запобігаючи витоків залишкової інформації між різними користувачами.	SC-4	Параметр: shared_resource_protection Тип: boolean Значення: true
151	ДОСТУПНІСТЬ РЕСУРСІВ (SC-6)	Забезпечити захист доступності ресурсів, виділивши [Призначення: визначені організацією ресурси], по [Вибір (один або кілька); пріоритет; квоти; [Призначення: визначені організацією заходи з безпеки]].	SC-6	Параметр: Визначені засоби контролю для захисту доступності ресурсів (якщо вибрано) Тип: string Значення: автоматизований засіб моніторингу
152	ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)	Всі зовнішні підключення приймаються виключно через єдиний порт (керований інтерфейс), що обробляється веб-сервером (Cowboy). Доступ до внутрішніх API і вузлів кластера блокується правилами мережевого екранування за замовчуванням (Default Deny).	SC-7	Параметр: boundary_protection Тип: boolean Значення: true
153	ЗАХИСТ ПЕРИМЕТРА - ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))		SC-7(5)	
154	КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)	Передача інформації між клієнтом і сервером здійснюється виключно через зашифровані канали (WSS/TLS), що унеможливує перехоплення (Man-in-the-Middle) або несанкціоновану модифікацію даних на льоту.	SC-8	Параметр: transmission_confidentiality Тип: boolean Значення: true
155	КОНФІДЕНЦІЙНІСТЬ ТА КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-8(1))		SC-8(1)	
156	ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)	Протокол N2O автоматично розриває мережеве з'єднання після завершення комунікаційного сеансу або перевищення часу очікування (Inactivity Timeout), звільняючи ресурси та сесію.	SC-10	Параметр: network_disconnect_timeout Тип: integer Значення: 3600
157	ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)	Керування ключами та сертифікатами для встановлення захищених з'єднань делегується бібліотеці 'sync/ca' та інтегрованим механізмам TLS ОС, що відповідають чинним криптографічним стандартам.	SC-12	Параметр: cryptographic_key_management Тип: boolean Значення: true
158	КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)	Система підтримує використання схвалених криптографічних алгоритмів (AES-GCM, SHA-256/512, ДСТУ 4145-2002 через відповідні модулі), які забезпечують необхідний рівень стійкості.	SC-13	Параметр: cryptographic_protection Тип: boolean Значення: true
159	СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)	а. Заборонити віддалену активацію спільних обчислювальних пристроїв (хмар) та застосунків з такими виключеннями: [Призначення: визначені організацією виключення, у яких дозволена віддалена активація]. б. Надати явну вказівку щодо використання користувачами фізично присутніми пристроями.	SC-15	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
160	СЕРТИФІКАТИ ІНФРАСТРУКТУРИ ВІДКРИТИХ КЛЮЧІВ (SC-17)	а. Випускати сертифікати відкритого ключа відповідно до [Призначення: визначеної організацією політики сертифікації]; б. Отримувати сертифікати відкритого ключа від затвердженого постачальника послуг.	SC-17	
161	МОБІЛЬНИЙ КОД (SC-18)	а. Визначати прийнятні та неприйнятні мобільні коди та технології мобільних кодів. б. Проводити авторизацію, відстежувати та контролювати використання мобільного коду всередині системи.	SC-18	
162	АВТЕНТИФІКАЦІЯ СЕСІЙ (SC-23)	Автентичність WebSocket-сесій N2O захищається токенами з криптографічним підписом (HMAC). Це гарантує, що повідомлення в рамках сесії не можуть бути підроблені або інжектвані сторонньою особою.	SC-23	Параметр: session_authenticity Тип: boolean Значення: true
163	ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)	Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] [Призначення: визначена організацією інформація] в стані спокою.	SC-28	
164	ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ КРИПТОГРАФІЧНИЙ ЗАХИСТ		SC-28(1)	Параметр: Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях Тип: string Значення: AES-256-GCM Параметр: Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях Тип: string Значення: AES-256-GCM
165	ЕКРАНОВАНІ КАМЕРИ (SC-44)	Впровадити екрановані камери в [Призначення: визначену організацією систему, компонент системи або місце розташування].	SC-44	

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
166	ПРИМУСОВЕ АПАРАТНЕ ЗАБЕЗПЕЧЕННЯ ВИКОНАННЯ (SC-49)	Впровадити механізми апаратного поділу та застосування політики між [Призначення: домени безпеки, визначені організацією].	SC-49	Параметр: Впроваджено механізми апаратного розділення та застосування політик між доменами безпеки Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Визначені домени безпеки, які потребують апаратного розділення та механізмів забезпечення дотримання політики Тип: list Значення: default _deny_rule, abac _rule_1
167	АПАРАТНИЙ ЗАХИСТ (SC-51)	a. Перевіряти правильність роботи [Призначення: визначені організацією функції безпеки та приватності]. b. Виконувати перевірку [Вибір (один або кілька): [Призначення: визначені організацією системні перехідні стани]; за командою користувача з відповідними повноваженнями; [Призначення: визначена організацією частота]]. c. Повідомляти [Призначення: визначені організацією персонал або посадові особи] про невдалі перевірки безпеки та приватності. d. [Вибір (один або кілька): Вимкнути систему; Перезапустити систему; [Призначення: визначені організацією альтернативні дії]], коли виявляються аномалії.	SC-51	Параметр: Визначені уповноважені особи, які повинні виконувати процедури вимкнення та повторного увімкнення апаратного захисту від запису; SC-51a. використовується апаратний захист від запису для компонентів мікропрограми системи; SC-51b.[01] впроваджено спеціальні процедури для уповноважених осіб для ручного вимкнення апаратного захисту від запису для модифікацій мікропрограми; SC-51b.[02] реалізовано спеціальні процедури для уповноважених осіб для повторного увімкнення захисту від запису перед поверненням до робочого режиму Тип: list Значення: admin, security_officer
17. ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ (SI) (SI)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
168	ПОЛІТИКА І ПРОЦЕДУРИ ЦІЛІСНОСТІ ІНФОРМАЦІЇ (SI-1)		SI-1	Параметр: Визначено персонал або ролі, до яких має бути доведена політика цілісності системи та інформації Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури цілісності системи та інформації Тип: list Значення: admin, security_officer Параметр: Визначено посадову особу, відповідальну за управління системою та політикою і процедурами цілісності інформації Тип: list Значення: admin, security_officer Параметр: Визначено періодичність перегляду та оновлення поточної політики цілісності системи та інформації Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Є події, які вимагають перегляду та оновлення поточної політики цілісності системи та інформації Тип: list Значення: default _deny_rule, abac_rule_1 Параметр: Визначено частоту, з якою переглядаються та оновлюються поточні цілісності системи та інформації Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
169	ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)		SI-2	Параметр: Визначено період часу, протягом якого необхідно встановити оновлення програмного забезпечення, пов'язані з безпекою, після виходу оновлень; SI-02a.[01] виявлено недоліки системи; SI-02a.[02] повідомляється про недоліки системи; SI-02a.[03] виправлені недоліки системи; SI-02b.[01] перевіряються оновлення програмного забезпечення, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[02] перевіряються оновлення програмного забезпечення, пов'язані з виправленням дефектів, на наявність потенційних побічних ефектів перед встановленням; SI-02b.[03] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[04] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на наявність потенційних побічних ефектів перед встановленням; SI-02c.[01] встановлено оновлення програмного забезпечення, що стосуються безпеки, протягом часовий проміжок з моменту випуску оновлень; SI-02c.[02] встановлено оновлення мікропрограми, що стосуються безпеки, протягом часового періоду з моменту випуску оновлень; SI-02d. включено відновлення порушених прав у процес управління організаційною конфігурацією Тип: integer Значення: 30

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
170	ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)		SI-3	Параметр: Визначено частоту, з якою механізми шкідливого коду виконують сканування Тип: integer Значення: 30 Параметр: Визначено дії, яких слід вжити у відповідь на виявлення шкідливого коду (якщо вибрано) Тип: list Значення: login, logout, failed_attempt
171	МОНІТОРИНГ СИСТЕМИ (SI-4)		SI-4	Параметр: Визначені методи та способи, що використовуються для виявлення несанкціонованого використання системи Тип: list Значення: admin, security_officer Параметр: Визначена інформація про моніторинг системи, яка повинна надаватися персоналу або ролям Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, яким має надаватися інформація про моніторинг системи Тип: list Значення: admin, security_officer Параметр: Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {за потребою; частота} Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
172	МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(4))		SI-4(4)	Параметр: Визначені критерії незвичної або несанкціонованої діяльності або умови для вхідного трафіку зв'язку Тип: list Значення: Параметр: Визначені критерії незвичайної або несанкціонованої діяльності або умови для вихідного трафіку зв'язку Тип: list Значення: Параметр: Здійснюється моніторинг вхідного трафіку частота на предмет незвичних або несанкціонованих дій або умов Тип: string Значення: щорічно Параметр: Контролюється вихідний трафік зв'язку частота на предмет незвичних або несанкціонованих дій або умов. вихідного виявлення Тип: string Значення: щорічно
173	ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)		SI-5	Параметр: Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {персонал або ролі; елементи; зовнішні організації} Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, до яких мають бути доведені попередження, поради та директиви з безпеки (якщо визначено) Тип: list Значення: admin, security_officer

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
174	ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ (SI-7)	а. Впровадити механізми захисту від спаму в точках входу та виходу системи, щоб виявляти та протидіяти небажаним повідомленням. б. Оновлювати механізми захисту від спаму, коли доступні нові механізми відповідно до організаційної політики та процедур управління конфігурацією.	SI-7	Параметр: Визначені дії, яких слід вжити при виявленні несанкціонованих змін у програмному забезпеченні Тип: list Значення: login, logout, failed_attempt Параметр: Визначені дії, яких слід вжити несанкціонованих змін у прошивці; при виявленні SI-07_ODP[06] визначені дії, яких слід вжити несанкціонованих змін до інформації; при виявленні SI-07a.[01] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін у програмному забезпеченні; SI-07a.[02] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін у мікропрограмі; SI-07a.[03] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін до інформації; SI-07b.[01] виконуються дії при виявленні несанкціонованих змін у програмному забезпеченні; SI-07b.[02] виконуються дії несанкціонованих змін у прошивці; при виявленні SI-07b.[03] виконуються дії несанкціонованих змін в інформації. при виявленні Тип: list Значення: login, logout, failed_attempt

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
175	УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)	Управляти та зберігати інформацію всередині системи та виводити інформацію із системи відповідно до чинного законодавства, виконавчих наказів, директив, правил, політик, стандартів, керівних принципів та експлуатаційних вимог.	SI-12	Параметр: Здійснюється управління інформацією в системі відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Зберігається інформація в системі відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Управління інформацією, що виводиться з системи, здійснюється відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та операційних вимог Тип: list Значення: default _deny_rule, abac _rule_1 Параметр: Зберігається інформація, що виводиться з системи, відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Тип: list Значення: default _deny_rule, abac _rule_1
18. УПРАВЛІННЯ РИЗИКАМИ В ЛАНЦЮГУ ПОСТАЧАННЯ (SR) (SR)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
176	ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-1)	а. Розробіть, задокументуйте та поширте [Призначення: персонал або ролі, визначені організацією]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика управління ризиками ланцюга постачання, яка: а) Розглядає мету, сферу діяльності, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та відповідність; б) Відповідає чинним законам, виконавчим наказам, директивам, положенням, політикам, стандартам і вказівкам; 2. Процедури для сприяння впровадженню політики управління ризиками ланцюга постачання та відповідних засобів контролю управління ризиками ланцюга постачання; б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур управління ризиками ланцюга постачання; с. Перегляньте та оновіть поточне управління ризиками ланцюга постачання: 1. Політика [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].	SR-1	Параметр: Визначено персонал або ролі, на які поширюється політика управління ризиками ланцюга постачання Тип: list Значення: admin, security_officer Параметр: Визначено персонал або ролі, на які поширюються процедури управління ризиками ланцюга постачання Тип: list Значення: admin, security_officer Параметр: Визначена посадова особа, відповідальна за розробку, документування та розповсюдження політики та процедур управління ризиками ланцюга постачання Тип: list Значення: admin, security_officer Параметр: Визначена періодичність перегляду та оновлення поточної політики управління ризиками ланцюга постачання Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Є події, які вимагають перегляду та оновлення поточної політики управління ризиками ланцюга постачання Тип: list Значення: default_deny_rule, abac_rule_1 Параметр: Визначена періодичність перегляду та оновлення поточної процедури управління ризиками ланцюга постачання Тип: string Значення: щорічно

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
177	ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)	План управління базується на принципі відмови від стороннього коду. Замість інтеграції сотень неперевіраних бібліотек, команда розробляє всі необхідні компоненти (веб-сервер N2O, KVS, CA) самостійно в єдиному монорепозіторії.	SR-2	Параметр: zero_dependency_policy Тип: boolean Значення: true
178	КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)	Заборонено використання автоматичних менеджерів пакетів для завантаження коду під час збірки. Весь вихідний код системи та модулів міститься безпосередньо в репозиторії проекту, що гарантує 100% контроль над кожним рядком коду, який компілюється.	SR-3	Параметр: strict_code_vendoring Тип: boolean Значення: true
179	СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)	Використовуйте наступні стратегії придбання, контрактні інструменти та методи закупівель, щоб захистити від ризиків ланцюга постачання, визначити та пом'якшити їх: [Призначення: визначені організацією стратегії придбання, контрактні інструменти та методи закупівель].	SR-5	
180	ОЦІНКА ПОСТАЧАЛЬНИКІВ (SR-6)	Єдиним зовнішнім «постачальником» є розробник платформи Erlang/OTP (компанія Ericsson та спільнота). Оновлення версій OTP проходять жорстку перевірку перед їх застосуванням на продуктивних серверах.	SR-6	Параметр: erlang_otp_supplier_review Тип: boolean Значення: true